

financial-coverage

Financial Application Coverage

Preston-Check is positioned as a financial-systems security scanner, so the catalog goes well beyond generic web-application security into fintech-specific patterns. This document audits what's currently covered in the value-handling domain and surfaces gaps worth closing for v1.1+.

What's covered today

The financial-system catalog spans roughly fifty check categories. The strongest current coverage is in the categories that map directly to the originating attack pattern that gave the project its name.

Money type and arithmetic safety is well covered: P-50 (Transaction Integrity) catches `float` / `double` for monetary values and missing `RoundingMode` declarations; P-101 (Money Type Precision) extends this to multi-language (Java `BigDecimal`, Python `Decimal`, Go `decimal.Decimal`, Rust `rust_decimal::Decimal`, TypeScript `Decimal.js`); P-102 (Financial Math Accuracy) checks for division without scale, premature truncation, and unsafe rounding modes; P-81 (Financial Input Guards) catches negative amounts, integer overflow, NaN/Infinity, zero-amount edge cases.

Settlement and ledger correctness is strong: P-70 (Settlement Finality) verifies append-only ledgers, no transaction deletion, no status rewinds; P-74 (Proof of Reserves) checks balance reconciliation, overdraft prevention, and double-entry patterns; P-78 (Ledger Consistency) catches atomic balance updates, drift detection, orphaned entries; P-103 (Double-Spend Race) detects missing locking on financial mutations.

Transaction lifecycle controls are well covered: P-65 (Transaction Velocity) catches rapid-fire transactions and structuring patterns; P-73 (Transaction Limits) verifies per-transaction and rolling limits; P-76 (Payment State Machine) validates state transitions and terminal states; P-77 (Withdrawal Controls) checks limits, address whitelists, cooldowns, 2FA on withdrawals.

KYC, AML, and sanctions are present: P-22 (AML Transaction Monitoring), P-23 (KYC Document Security), P-71 (Beneficial Ownership), P-72 (Sanctions Screening) covering OFAC, PEP, country restrictions; P-66 (Dormant Account Monitoring) detects reactivation anomalies.

Fee and rate manipulation are caught by P-68 (Fee Manipulation) for negative fees and client-supplied fees, plus P-69 (Exchange Rate Safety) for stale rates, rate bounds, and spread limits.

Audit and event sourcing: P-09 (Audit Trail), P-75 (Audit Immutability), P-80 (Financial Event Sourcing) cover append-only event logs, history tables, and point-in-time queries.

Withdrawal and approval workflows: P-56 (Multi-Signature Approval) verifies dual-approval workflows and Fireblocks co-signer/TAP integration.

Crypto-specific: P-55 (Crypto Address Security) for address validation, whitelisting, and AML screening on outbound crypto.

Gap analysis — value-handling

Despite the strong catalog, there are several material gaps when scanning applications that move money:

PSD2 Strong Customer Authentication (SCA) is not explicitly checked. European fintechs are required to enforce SCA on payment initiation and account access; absence of dynamic linking, two-factor enforcement on transaction signatures, and inherence-element use are common audit findings.

3DS / 3D Secure 2 integration is uncovered. CNP (card-not-present) transactions in Europe and increasingly the US require 3DS2 with proper exemption handling (TRA, low-value, recurring). Missing or misconfigured 3DS integrations create both fraud exposure and regulatory exposure.

Chargeback and dispute handling is uncovered. Improperly written chargeback workflows can leak customer PII, fail to apply representment deadlines, or miscalculate dispute reserves. PSD2 and Reg E require specific timelines and notifications.

Recurring billing safety is uncovered. Subscription mutations (quantity changes, plan upgrades, mid-cycle proration) are a common vector for revenue leakage and customer-facing billing errors. Specific checks: idempotency on plan-change endpoints, proration math correctness, trial-to-paid transitions.

Slippage and MEV protection for crypto fintechs is uncovered. Decentralized exchange integrations need slippage limits, deadlines on swap transactions, and protection against sandwich attacks.

Bridge and cross-chain security is uncovered. The largest crypto exploits in 2022–2024 were bridge hacks; checks for replay protection across chains, validator-set verification, and time-locked governance are absent.

Stablecoin peg verification is uncovered. Stablecoin issuers and exchanges need automated peg deviation detection and circuit breakers.

Oracle manipulation resistance for DeFi pricing is uncovered.

Reserve and capital adequacy reporting beyond P-74 is light. Basel III banks and major non-bank financials need automated capital ratio calculations, liquidity coverage ratio (LCR), and net stable funding ratio (NSFR) checks.

Tax calculation correctness is uncovered. Multi-jurisdiction fintechs need automated tests for VAT/GST handling, withholding tax deductions, and 1099/T5 reporting accuracy.

Algorithmic discrimination in credit underwriting is uncovered. Fair-lending regulations (ECOA, Reg B in the US; FCA principles in the UK) require demonstrable evenhandedness in credit decisions. Static checks for prohibited-basis variables in model features and absence of adverse-action explanation paths would catch many issues.

Travel Rule compliance for crypto remittances over thresholds is partially covered (P-77 references Travel Rule) but lacks dedicated checks for FATF Recommendation 16 originator/beneficiary information fields.

Card tokenization quality beyond P-21's PAN-storage check is uncovered. PCI 4.0 and the Software Security Framework (SSF) require validation that tokenization vendors are PCI-listed, tokens cannot be detokenized outside the secure environment, and replacement values follow PAN-format-preserving rules where claimed.

Open Banking API security is uncovered. PSD2 RTS for Account Information Service Providers (AISPs) and Payment Initiation Service Providers (PISPs) requires specific OAuth 2.0 + PSD2 flows that are often misconfigured.

Wallet custody patterns: HSM integration verification, MPC threshold signature scheme validation, and air-gapped key ceremony evidence are uncovered. P-36 (Key Management) catches some patterns but not custody-specific concerns.

Gap analysis — broader payment ecosystem

SEPA payment compliance for European fintechs: missing IBAN validation, missing SEPA Instant Payment 10-second SLA awareness, and SEPA Direct Debit mandate handling.

Real-time payment systems (FedNow in US, FPS in UK, UPI in India, PIX in Brazil): each has distinct requirements around irrevocability, fraud screening, and dispute timelines. None are explicitly checked.

Card scheme compliance: Visa CFRP and Mastercard fraud reduction program rules. Specific dispute volume thresholds, fraud volume thresholds, and reporting cadences.

Refund integrity: detection of refunds that exceed original payment, refunds without matching capture, and refund reuse attacks. Touched in P-78 (Ledger Consistency) but not explicit.

Pre-authorization handling: holds that exceed authorization windows, void-vs-refund correctness, capture-after-expiry. Common fintech bug class.

Roadmap — financial coverage

v1.1 — Payment ecosystem (priority)

Target categories: PSD2 SCA enforcement, 3DS2 integration, chargeback/dispute workflows, recurring-billing safety, refund integrity, pre-authorization correctness. These map to the most common payment- provider integrations and address the largest fintech buyer audience.

Estimated check count: 12–15 categories.

v1.2 — DeFi and crypto-specific

Target categories: slippage protection, MEV/sandwich resistance, bridge replay protection, oracle manipulation resistance, stablecoin peg verification, smart contract reentrancy (Solidity), integer overflow in pre-0.8 Solidity, governance time-locks. This is a larger expansion that warrants the dedicated `checks/defi/` namespace described in the language coverage document.

Estimated check count: 15–20 categories.

v1.3 — Capital and tax

Target categories: Basel III LCR/NSFR calculations, capital ratio reporting, multi-jurisdiction tax (VAT, GST, withholding, 1099/T5), fair-lending model checks for prohibited-basis variables.

Estimated check count: 8–12 categories.

v1.4 — Custody and wallet

Target categories: HSM integration verification, MPC threshold signature scheme validation, key-ceremony evidence, air-gap signing process documentation, hot/warm/cold wallet ratio policies.

Estimated check count: 6–10 categories.

Contributing financial checks

Financial checks are particularly well-suited to community contribution because expertise is concentrated in people who actually work in payments, treasury, and risk teams. A contributor with PSD2 experience can ship a pair of high-quality SCA-enforcement checks faster than an outside maintainer could research the regulatory text.

When authoring financial checks, always include the `regulatory_basis` or `frameworks` metadata field with specific regulation citations (e.g., `PSD2 Art. 97`, `12 CFR § 1005.6`). Auditors use these citations to map findings to their evidence requirements, so accuracy matters more than for generic-security checks.